

MARCO INTEGRATIVO GQM+ PRAGMATIC

Indicadores EPSS con Trazabilidad Objetivo-Métrica y Evaluación de Practicidad

Versión: 1.0

Fecha: Enero 2026

Clasificación: Información Operacional

Audiencia: Estrategas de Ciberseguridad, Científicos de Datos, Auditores Internos

INTRODUCCIÓN: CONVERGENCIA METODOLÓGICA

Este documento integra dos marcos metodológicos de clase mundial:

1. GQM (Goal-Question-Metric) - Victor Basili, Universidad de Maryland
2. Asegura trazabilidad: Objetivo Estratégico → Pregunta de Negocio → Métrica Técnica
3. Enfoque "arriba-hacia-abajo" (top-down)
4.
Garantiza que cada métrica resuelve pregunta, cada pregunta sirve objetivo
5.
PRAGMATIC (Practical, Relevant, Actionable, Genuine, Significant, Precise, Opportune, Independent, Cost-effective)
6. Asegura que métricas son prácticas en contexto real organizacional
7. Evalúa si métrica puede ejecutarse, interpretarse y actionar realmente
8. Enfoque "abajo-hacia-arriba" (bottom-up) de viabilidad

Garantiza que cada métrica resuelve pregunta, cada pregunta sirve objetivo

PRAGMATIC (Practical, Relevant, Actionable, Genuine, Significant, Precise, Opportune, Independent, Cost-effective)

Resultado: Framework que garantiza métricas EPSS son:

- ✓ **Trazables** a objetivos nacionales/regulatorios (NIS2, GDPR, ENS)
- ✓ **Prácticas** (factibles de medir, reportar, actionar)
- ✓ **Impactantes** (mejoran real decision-making)

PARTE 1: ESTRUCTURA JERÁRQUICA GQM APLICADA A EPSS

Nivel 1: OBJETIVO ESTRATÉGICO (Goal)

OBJETIVO GENERAL (Nivel Corporativo/Nacional)

"Mejorar resiliencia cibernética nacional mediante gestión inteligente de vulnerabilidades, priorizando amenazas reales (probabilidad de explotación) sobre ruido de severidad teórica, alineándose con NIS2 (Art 21-E: 'proporcionalidad') y GDPR (Art 32: 'medidas técnicas y organizativas')"

↓ (DESCOMPONE EN)

OBJETIVOS SECUNDARIOS (Nivel Organizacional)

- OB-1: Reducir MTTR (Mean Time to Remediate) de vulnerabilidades críticas mediante priorización basada en EPSS
- OB-2: Maximizar eficiencia operativa (= reducir trabajo inútil en CVEs que nunca serán explotadas)
- OB-3: Demostrar cumplimiento regulatorio de "proporcionalidad" mediante auditoría de decisiones de priorización
- OB-4: Mejorar MTTD (Mean Time to Detect) priorizando amenazas que EPSS predice con alta probabilidad en próximos 30 días

Nivel 2: PREGUNTA DE NEGOCIO (Question)

Cada objetivo se descompone en **preguntas que definen operacionalmente** qué significa "éxito":

OBJETIVO OB-1: Reducir MTTR vulnerabilidades críticas

- Q1.1: ¿Cuál es MTTR actual para vulnerabilidades priorizadas por EPSS $\geq$ 0.50?
└ Responde: Baseline de desempeño operativo
- Q1.2: ¿Cuál es MTTR para vulnerabilidades NO priorizadas por EPSS (EPSS<0.05)?
└ Responde: Efecto de segmentación por EPSS
- Q1.3: ¿Se ha reducido MTTR críticas en $\geq$ 20% vs baseline pre-EPSS?
└ Responde: Efectividad de priorización
- Q1.4: ¿Es la reducción MTTR estadísticamente significativa ($p<0.05$)?
└ Responde: Confianza en mejora (vs ruido aleatorio)

OBJETIVO OB-2: Maximizar eficiencia operativa

- Q2.1: ¿Qué % de esfuerzo remediación se dedica a CVEs que nunca son explotadas?
└ Responde: Desperdicio de recursos
- Q2.2: ¿Cuál es ratio esfuerzo/beneficio: % del tiempo en $\leq$ 20% de CVEs (riesgosos)?
└ Responde: Concentración de valor
- Q2.3: ¿Se logra 70%+ cobertura de vulnerabilidades realmente explotadas dedicando <30% del esfuerzo tradicional?
└ Responde: Eficiencia ganada vs cobertura mantenida

OBJETIVO OB-3: Cumplimiento regulatorio proporcional

- Q3.1: ¿Existe matriz documentada: EPSS score $\rightarrow$ SLA remediación?
└ Responde: Proporcionalidad demostrable (req NIS2 Art 21-E)
- Q3.2: ¿Se audita que decisiones priorización se basan en EPSS + contexto?
└ Responde: Trazabilidad auditoria (req GDPR Art 32)

OBJETIVO OB-4: Mejorar MTTD mediante EPSS

- Q4.1: ¿Qué % de CVEs que EPSS predice con EPSS $\geq$ 0.70 aparecen en KEV dentro 30 días?
└ Responde: Validez predictiva de EPSS (¿predice bien?)
- Q4.2: ¿Se integra EPSS en alertas SIEM para priorizar monitoreo?
└ Responde: Operacionalización (¿se usa realmente?)

Nivel 3: MÉTRICA TÉCNICA (Metric)

Cada pregunta se resuelve con **una o más métricas** cuantificables:

Q1.1: MTTR actual para EPSS $\geq$ 0.50

└ MÉTRICA: M1.1.1 = Promedio (Fecha_Remediation - Fecha_Detection)
para vulnerabilidades con EPSS_Score $\geq$ 0.50

Cálculo: $MTTR_high_EPSS = \frac{\sum(Remediation_Date - Detection_Date)}{Count(EPSS \geq 0.50)}$

Unidad: Días

Frecuencia: Mensual

Target: $\leq$ 7 días (NIS2)

Q1.2: MTTR para EPSS $<$ 0.05

└ MÉTRICA: M1.2.1 = Promedio (Fecha_Remediation - Fecha_Detection)
para vulnerabilidades con EPSS_Score $<$ 0.05

Cálculo: $MTTR_low_EPSS = \frac{\sum(Remediation_Date - Detection_Date)}{Count(EPSS < 0.05)}$

Unidad: Días

Frecuencia: Mensual

Target: $\leq$ 60 días (ciclo regular)

Q1.3: Reducción MTTR (%)

└ MÉTRICA: M1.3.1 = % Mejora = $\frac{(MTTR_Baseline - MTTR_Actual)}{MTTR_Baseline} \times 100$

Unidad: Porcentaje

Frecuencia: Trimestral

Target: $\geq$ 20% reducción

Q2.1: % Esfuerzo en CVEs nunca explotadas

└ MÉTRICA: M2.1.1 = $\frac{(Horas_Remediación_No_Explotadas)}{Horas_Totales_Remediación} \times 100$

Donde:

- Horas_Remediación_No_Explotadas = suma horas invertidas en CVEs que nunca fueron explotadas (verificado vs KEV histórico)
- Horas_Totales_Remediación = suma todas horas remediación

Unidad: Porcentaje

Frecuencia: Trimestral

Target: $\leq$ 30% (optimista: $\leq$ 20%)

Q3.1: Matriz Proporcionalidad Documentada

└ MÉTRICA: M3.1.1 = ¿Existe? (Binaria: Sí/No)
Más preciso: M3.1.2 = $\frac{(\# \text{ de decisiones priorización auditadas adherentes a matriz})}{Total \text{ decisiones auditadas}} \times 100$

Unidad: Presente/Ausente o Porcentaje

Frecuencia: Anual (auditoría)

Target: $\geq$ 95% adherencia

Q4.1: Validez Predictiva EPSS (Sensibilidad)

└ MÉTRICA: M4.1.1 = $\frac{(\# \text{ de CVEs con EPSS} \geq 0.70 \text{ que aparecen en KEV dentro 30 días})}{(Total \text{ CVEs con EPSS} \geq 0.70)} \times 100$

Alternativa = Recall/Sensitivity de EPSS

Unidad: Porcentaje
Frecuencia: Mensual
Target: $\geq 60\%$ (EPSS predice mejor que azar)

PARTE 2: ESTRUCTURA PRAGMATIC (9 CRITERIOS)

Para cada métrica anterior, evaluamos **9 dimensiones de practicidad**:

Criterio 1: PREDICTIVO (Predictive)

Pregunta: ¿La métrica **predice futuros riesgos** o solo describe lo pasado?

MÉTRICA: MTTR_high_EPSS (M1.1.1)

Evaluación PREDICTIVA:

- ¿Es retrospectivo? SÍ (mide MTTR pasado)
- ¿Tiene poder predictivo? PARCIAL
 - └ Si MTTR_histórico ↓, predice mejor remediación futura
 - └ Si MTTR_histórico → ∞, predice problema futuro

CALIFICACIÓN: 6/10 (Retrospectivo con componente predictivo limitado)

MEJORA: Agregar trend de MTTR (¿mejora o empeora mes-a-mes?)

→ Métrica M1.1.2 = $\text{Trend MTTR} = (\text{MTTR}_{\text{mes_actual}} - \text{MTTR}_{\text{mes_anterior}}) / \text{MTTR}_{\text{mes_anterior}}$
→ Calificación mejorada: 8/10

Criterio 2: RELEVANTE (Relevant)

Pregunta: ¿Tiene la métrica **significancia para stakeholders** (técnicos, ejecutivos, auditores)?

MÉTRICA: MTTR_high_EPSS (M1.1.1)

Evaluación RELEVANCIA:

- Para CISO: SÍ (demuestra velocidad respuesta, KPI estratégico)
- Para CFO: SÍ (correlaciona con reducción exposición de riesgo → menor ALE)
- Para Auditor: SÍ (evidencia de cumplimiento NIS2 Art 21-E)
- Para Desarrollador: SÍ (target operacional claro)

CALIFICACIÓN: 9/10 (Altamente relevante para múltiples stakeholders)

Criterio 3: ACCIONABLE (Actionable)

Pregunta: ¿Se puede **tomar acción** concreta basada en la métrica?

MÉTRICA: MTTR_high_EPSS (M1.1.1)

Evaluación ACCIONABILIDAD:

- Si MTTR_high_EPSS = 14 días (vs target ≤ 7 días)
 - └ Acción 1: Aumentar recursos remediación
 - └ Acción 2: Automatizar patching para EPSS ≥ 0.70
 - └ Acción 3: Investigar bottlenecks (¿validación? ¿cambio? ¿testing?)
 - └ Acción 4: Revisar SLA (¿realista target ≤ 7 días?)
- Métrica claramente muestra "qué está mal" (MTTR alto)

CALIFICACIÓN: 8/10 (Claramente accionable)

Excepción: Si = "MTTR_high_EPSS = 3 días", sin contexto de qué cambió,
accionabilidad = 5/10 (¿qué mantener? ¿qué mejorar?)

Criterio 4: GENUINO (Genuine)

Pregunta: ¿Mide realmente lo que pretende medir (validez de constructo)?

MÉTRICA: MTTR_high_EPSS (M1.1.1)

Evaluación GENUINIDAD:

- ¿Pretende medir? "Velocidad remediación de vulnerabilidades altas riesgo"
- ¿Realmente mide eso?
 - └ Sí: incluye únicamente CVEs con EPSS ≥ 0.50 (riesgo alto)
 - └ Sí: mide tiempo real remediación (no tiempo planificado)
 - └ PERO: ¿incluye reintento si falló primer parche? (sesgo posible)
 - └ PERO: ¿incluye vulnerabilidades parcialmente remediadas? (definición ambigua)

CALIFICACIÓN: 7/10 (Mide concepto, pero requiere definiciones claras)

MEJORA: Definir precisamente qué = "remediado"
(ej: vulnerabilidad re-escaneada confirma eliminación)

Criterio 5: SIGNIFICATIVO (Significant)

Pregunta: ¿El tamaño del efecto es lo bastante grande para importar?

MÉTRICA: MTTR_high_EPSS (M1.1.1)

Escenario 1: MTTR se reduce de 30 días → 28 días

- Diferencia: 2 días (6.7% mejora)
- Significancia: BAJA (cambio marginal, podría ser ruido)
- CALIFICACIÓN: 3/10

Escenario 2: MTTR se reduce de 30 días → 7 días

- Diferencia: 23 días (76% mejora)
- Significancia: ALTA (cambio claro, práctico)
- CALIFICACIÓN: 9/10

Recomendación: Definir "Mejora Significativa Mínima" = cambio que importa
(ej: si diferencia < 5 días, no reportar como "mejora")

Criterio 6: PRECISO (Precise)

Pregunta: ¿Se mide con exactitud y sin ambigüedad?

MÉTRICA: MTTR_high_EPSS (M1.1.1)

Evaluación PRECISIÓN:

- ¿Está bien definida "fecha detección"?
 - └ Ambiguo: ¿Cuando scanner detecta? ¿Cuando analista lo ve? ¿Cuando se verifica?
 - └ Solución: Definir "Fecha_Detección = primer timestamp de alert en SIEM validado"
- ¿Está bien definida "fecha remediación"?
 - └ Ambiguo: ¿Cuando parche se aplica? ¿Cuando se verifica? ¿Cuando se cierra ticket?
 - └ Solución: Definir "Fecha_Remediación = re-escaneo confirma vulnerabilidad eliminada"
- ¿Se miden automáticamente o manualmente?
 - └ Si manual: precisa baja (sesgo humano)
 - └ Si automática (de logs): precisa alta

CALIFICACIÓN: 6/10 (Requiere mejor definición de términos)

MEJORA RECOMENDADA: Crear "Diccionario de Métrica" con definiciones explícitas
→ Calificación mejorada a 8/10

Criterio 7: OPORTUNO (Opportune/Timely)

Pregunta: ¿Se mide y reporta con frecuencia suficiente para decisiones?

MÉTRICA: MTTR_high_EPSS (M1.1.1)

Evaluación OPORTUNIDAD:

- Frecuencia de cálculo: Mensual
- ¿Es suficientemente frecuente?
 - └ Para decisiones tácticas (team lead): SÍ (mensual es razonable)
 - └ Para decisiones operativas (CISO): MAYBE (preferible semanal)
 - └ Para alertas real-time: NO (necesita daily/hourly)
- Latencia de reporte: ¿Cuánto tarda en reportarse?
 - └ Si reporta día 5 del mes siguiente: BAJA oportunidad
 - └ Si reporta día 1 del mes: ALTA oportunidad

CALIFICACIÓN: 7/10 (Mensual es razonable, podría mejorar a semanal)

Criterio 8: INDEPENDIENTE (Independent)

Pregunta: ¿Es la métrica independiente de factores externos/sesgos?

MÉTRICA: MTTR_high_EPSS (M1.1.1)

Evaluación INDEPENDENCIA:

- ¿Se ve afectada por factores no controlables?
 - └ RIESGO 1: Si nuevas vulnerabilidades EPSS $\geq$ 0.50 llegan, mezclan datos históricos
 - └ RIESGO 2: Si equipo remediación es retenido/despedido, cambio artificial en MTTR
 - └ RIESGO 3: Si herramienta de scanning cambia, fechas pueden resetear
- ¿Se puede aislar efecto de mejoras (vs confounding variables)?
 - └ Difícil: si MTTR mejora por "más recursos" vs "mejor priorización EPSS"

CALIFICACIÓN: 5/10 (Vulnerable a factores externos)

MEJORA: Usar análisis causal (ej: regression analysis) para aislar efecto EPSS
→ Calificación mejorada a 7/10

Criterio 9: RENTABLE (Cost-effective/Economical)

Pregunta: ¿El costo de medir la métrica es proporcional al valor que aporta?

MÉTRICA: MTTR_high_EPSS (M1.1.1)

Evaluación COSTO-BENEFICIO:

- Costo de medir:
 - └ Recolección automática de logs: €0 (ya existe)
 - └ Análisis mensual: €500 (1 analyst × 4 horas × €125/h)
 - └ Reportaría: €100 (dashboard generation)
 - └ COSTO TOTAL MENSUAL: €600 (~€7K/año)
- Beneficio:
 - └ Si MTTR se reduce 50%, exposición de riesgo ↓ €100K/mes
 - └ ROI: €100K beneficio / €0.6K costo = 167x

CALIFICACIÓN: 10/10 (Extremadamente rentable)

Nota: Si métrica fuera costosa de recopilar (ej: manual auditoría de 40 horas/mes), rentabilidad sería 2/10 (no justifica costo).

PARTE 3: MATRIZ GQM+ PRAGMATIC INTEGRADA

OBJETIVO → PREGUNTA → MÉTRICA → EVALUACIÓN PRAGMATIC (9 criterios)

OB-1: Reducir MTTR

- Q1.1: MTTR actual ($EPSS \geq 0.50$)?
 - M1.1.1: MTTR_high_EPSS (días)
 - PRAGMATIC SCORES:
 - Predictivo: 6/10
 - Relevante: 9/10
 - Accionable: 8/10
 - Genuino: 7/10
 - Significativo: Depende escenario (3-9/10)
 - Preciso: 6/10 (mejora a 8/10 con diccionario)
 - Oportuno: 7/10
 - Independiente: 5/10
 - Rentable: 10/10
 - PROMEDIO PRAGMATIC: 7.3/10 (BUENA)
- Q1.2: MTTR actual ($EPSS < 0.05$)?
 - M1.2.1: MTTR_low_EPSS (días)
 - PRAGMATIC: Similar a M1.1.1 (7.3/10)
- Q1.3: ¿Mejora MTTR?
 - M1.3.1: % Mejora MTTR
 - PRAGMATIC: 8.1/10 (más accionable, más significativo)

[Continuar para OB-2, OB-3, OB-4...]

CONCLUSIÓN: FRAMEWORK APLICADO

Este marco garantiza que cada **métrica EPSS**:

9. ✓ Remonta a objetivo estratégico (NIS2, resiliencia nacional)
10. ✓ Responde pregunta de negocio clara (¿qué se quiere saber?)
11. ✓ Se cuantifica sin ambigüedad (formula matemática, definiciones)
12. ✓ Se evalúa en practicidad (9 dimensiones pragmáticas)
13. ✓ Se reporta accionable (equipo sabe qué hacer si score es malo)

Resultado final: Metrics dashboard que es **auditable, justificable y útil**.

Marco GQM+PRAGMATIC desarrollado por Consorcio de Científicos de Datos y Estrategas de Ciberseguridad

Enero 2026